

Methane & CO2 Tracker

Relatório da Fase 7 — Autenticação JWT Individual

Nota: relatório reconstruído retroativamente em 2026-08-08 — a Fase 7 nunca teve PDF gerado na época. Todo o conteúdo abaixo vem de evidência verificável no repositório (relatórios reais das Fases 3/5/6 já commitados, e leitura do código de autenticação exatamente como existia no commit 707028a), não de memória de sessão. Este repositório tem só 16 commits no total; o commit inicial já chega com as Fases 1-7 esmagadas juntas, então não existe diff git isolado só desta fase.

Escopo desta fase

Substituir a chave de API única compartilhada (header `X-API-Key` validado contra `settings.api_key_secret`, sem sessão/cookie — mecanismo descrito explicitamente nos relatórios das Fases 3, 5 e 6) por autenticação individual por usuário via JWT (e-mail + senha com hash).

Decisões de arquitetura desta fase

- `backend/alembic/versions/0003_add_users_table.py`: nova tabela **users** (id autoincrement, email único, password_hash, created_at com server_default now()) — revisão 0003, sobre a 0002.
- `backend/app/auth/security.py`: hash de senha via bcrypt. Detalhe de segurança notável: **verify_password** roda o `bcrypt.checkpw` contra um hash dummy fixo quando o e-mail informado não existe no banco — garante tempo de resposta igual em ambos os casos, para não vazar por timing se um e-mail está cadastrado ou não. Criação/validação de JWT via HS256, payload com sub (user id) e exp (expiração).
- `backend/app/api/deps.py`: **require_user** — valida o Bearer token e recarrega o usuário do banco a cada chamada (stateless-per-call, mesma filosofia do resto do projeto), 401 genérico em qualquer caso de falha (credenciais ausentes, token inválido, usuário não encontrado), sem distinguir o motivo exato pro cliente.
- `backend/app/api/routers/auth.py`: POST `/auth/login`, rate limit de 5/minuto.
- Routers readings, devices, alerts e reports migrados de `require_api_key` para `require_user` — confirmado em cada um via `dependencies=[Depends(require_user)]` na declaração do `APIRouter`.
- `main.py`: CORS `allow_headers` trocado para `["Authorization", "Content-Type"]` (era `X-API-Key`), `allow_methods` ganhou POST (necessário pra `/auth/login`).
- `create_admin_user.py`: script não-interativo com `--email` e `--password` como argumentos de linha de comando nesta versão original. **Nota**: passar a senha via `--password` foi corrigido depois (commit 35239e7, fora do escopo desta fase) pra usar `getpass` interativo, evitando senha salva no histórico do shell.
- Frontend: `App.tsx` guarda o JWT em `localStorage` sob a chave **mct_access_token**; `LoginForm.tsx` novo, com campos de e-mail e senha.

Arquivos entregues (snapshot desta fase)

Arquivo	Papel
<code>backend/alembic/versions/0003_add_users_table.py</code>	Cria a tabela users
<code>backend/app/auth/security.py</code>	Hash de senha (bcrypt) e criação/validação de JWT

backend/app/api/deps.py	Dependência require_user
backend/app/api/routers/auth.py	Endpoint POST /auth/login
backend/app/api/routers/{readings,devices,alerts,reports}.py	Migrados de require_api_key para require_user
backend/app/api/main.py	CORS ajustado (Authorization, POST)
backend/app/api/schemas.py	LoginRequest / TokenResponse
backend/scripts/create_admin_user.py	Criação de usuário via CLI
backend/tests/test_auth.py	Suíte de testes de autenticação
frontend/src/components/LoginForm.tsx	Formulário de login (e-mail + senha)
frontend/src/App.tsx	Armazenamento do token (mct_access_token)

Status de verificação

backend/tests/test_auth.py cobre, com asserções explícitas no próprio arquivo: login válido (200), senha errada (401), e-mail inexistente (401), endpoint protegido chamado sem token (401), token malformado (401), token expirado (401), e endpoint protegido com token válido (200) — 7 casos confirmados no código do teste.

Não incluído nesta fase (próximos passos, conforme registrado na época)

- A Fase 7 fecha exatamente o item que os relatórios das Fases 3, 5 e 6 vinham listando repetidamente como pendência ("login individual por usuário, hoje: chave única compartilhada").
- Nenhum shim de compatibilidade foi mantido — API_KEY_SECRET foi removido sem retrocompatibilidade.

Gerado automaticamente por backend/scripts/generate_phase7_report.py